

# REALMATCH+

## 로그인·회원·사용자정보 설계서

소셜 로그인, 계정 통합, 프로필 구조, 인증 API 를 중심으로 정리한 초기 설계 문서

|        |                                                                 |
|--------|-----------------------------------------------------------------|
| 문서 목적  | 전체 서비스 제안서 중 로그인·회원가입·사용자 정보 영역만 분리하여 별도 설계 기준으로 사용             |
| 적용 범위  | Apple·Google·Kakao·Naver 소셜 로그인, 계정 연동, 기본 회원 정보, 프로필 정보, 선호 조건 |
| 설계 원칙  | 로그인 수단은 여러 개여도 서비스 내부 사용자 계정은 하나로 통합                            |
| 초기 산출물 | DB 초안, 인증 플로우, 사용자 정보 구조, 핵심 API, 보안·운영 기준                      |

### 1. 로그인/회원 영역 설계 목표

- 모바일 앱 기준으로 소셜 로그인 중심의 회원 체계를 설계하고, 내부적으로는 하나의 사용자 계정으로 관리한다.
- 초기 MVP 단계에서는 가입 장벽을 낮추되, 이후 랜덤통화·결제·커뮤니티 기능 확장에 문제가 없도록 계정 구조를 먼저 안정화한다.
- 로그인 방식과 프로필 정보를 분리해 인증 도메인과 서비스 도메인이 뒤섞이지 않도록 한다.

### 2. 지원 로그인 방식 및 정책

- 지원 로그인: Apple Login, Google Login, Kakao Login, Naver Login
- 초기 기본 정책: 이메일/비밀번호 자체 가입보다 소셜 로그인을 우선 지원
- SSO 는 기업형 싱글사인온이 아니라, 여러 소셜 계정을 하나의 서비스 계정에 연결하는 계정 통합(Account Linking) 개념으로 적용
- 같은 제공자의 동일 provider\_user\_id 는 반드시 같은 사용자로 처리하며, 다른 제공자 간 자동 병합은 하지 않고 사용자 명시 연동 방식으로 운영

#### 2-1. 계정 통합 원칙

| 항목            | 정책                       | 이유                        |
|---------------|--------------------------|---------------------------|
| 동일 제공자 재로그인   | 기존 계정으로 바로 로그인           | 중복 회원 방지                  |
| 다른 제공자 이메일 동일 | 자동 병합하지 않음               | 애플 프라이빗 릴레이·이메일 미제공 이슈 방지 |
| 계정 연동         | 로그인 후 설정 화면에서 명시적으로 연결   | 사용자 의도 확인 및 오연결 방지        |
| 연동 해제         | 마지막 로그인 수단 하나만 남으면 해제 제한 | 계정 고립 방지                  |

### 3. 인증 구조 설계

- 클라이언트는 각 소셜 SDK 를 통해 인증을 수행하고, 서버에는 authorizationCode 또는 idToken 과 디바이스 정보를 전달한다.
- 서버는 제공자 토큰을 직접 검증한 뒤 provider\_user\_id 를 기준으로 기존 계정을 조회한다.
- 기존 계정이 없으면 users 와 user\_auth\_providers 를 생성하고, 있으면 마지막 로그인 시각과 디바이스 정보를 갱신한다.
- 최종적으로 서비스 전용 Access Token 과 Refresh Token 을 발급한다.

앱 소셜 인증 → 서버 검증 요청 → provider\_user\_id 확인 → 기존 계정 조회 → 신규 생성 또는 기존 로그인 → JWT 발급 → 사용자 정보 완성 여부 판단

## 4. 핵심 데이터 모델

### 4-1. 인증·회원 도메인 테이블

| 테이블                   | 주요 컬럼                                                                    | 설명                                |
|-----------------------|--------------------------------------------------------------------------|-----------------------------------|
| users                 | user_id, user_uuid, status, nickname, email, phone_number, last_login_at | 서비스 내부 사용자 본체. 로그인 수단과 분리된 기준 계정  |
| user_auth_providers   | user_id, provider_type, provider_user_id, provider_email, connected_at   | 외부 로그인 제공자와 내부 user 를 연결하는 매핑 테이블 |
| refresh_tokens        | user_id, token_hash, device_id, expires_at, revoked_at                   | 모바일 세션 유지와 로그아웃·재발급 처리를 위한 토큰 저장소 |
| user_devices          | user_id, device_id, device_os, app_version, push_token, last_seen_at     | 푸시 알림, 다중 로그인 관리, 디바이스 추적용 정보     |
| user_terms_agreements | user_id, terms_type, terms_version, is_agreed, agreed_at                 | 서비스/개인정보/마케팅 등 약관 동의 이력 관리        |

### 4-2. 사용자 정보 도메인 테이블

| 테이블                 | 주요 컬럼                                                                                                     | 설명                                 |
|---------------------|-----------------------------------------------------------------------------------------------------------|------------------------------------|
| user_profiles       | user_id, height_cm, job_title, education_level, mbti, introduction, region_code                           | 매칭과 소개에 필요한 확장 프로필. users 와 1:1 분리 |
| user_profile_images | user_id, image_url, image_order, is_main                                                                  | 프로필 사진 다건 관리와 대표 이미지 지정            |
| user_preferences    | user_id, preferred_gender, preferred_age_min, preferred_age_max, preferred_region_code, allow_random_call | 매칭 선호 조건과 랜덤통화 허용 여부를 분리 관리        |

## 5. 사용자 정보 입력 단계

- 1 단계(가입 직후 필수): 닉네임, 성별, 출생연도, 필수 약관 동의
- 2 단계(프로필 완성): 사진, 자기소개, 지역, 직업, 키, MBTI 등 매칭 품질에 직접 영향을 주는 정보
- 3 단계(선호 설정): 선호 성별, 선호 나이대, 선호 지역, 랜덤통화 허용 여부
- is\_profile\_completed 는 2 단계까지 완료했는지 여부를 기준으로 두고, 이후 추천·매칭 노출 가중치에 활용한다.

## 6. 핵심 API 범위

| 구분    | API                             | 역할                                |
|-------|---------------------------------|-----------------------------------|
| 인증    | POST /api/v1/auth/social/login  | 소셜 로그인 검증 및 서비스 토큰 발급             |
| 인증    | POST /api/v1/auth/token/refresh | Refresh Token 기반 Access Token 재발급 |
| 인증    | POST /api/v1/auth/logout        | Refresh Token 폐기 및 세션 정리          |
| 계정 연동 | POST                            | 현재 계정에 다른 소셜 로그인 수단 연             |

|       |                                    |                        |
|-------|------------------------------------|------------------------|
|       | /api/v1/auth/providers/link        | 결                      |
| 내 정보  | GET /api/v1/users/me               | 기본 회원 정보 조회            |
| 내 정보  | PATCH /api/v1/users/me             | 닉네임·연락처 등 기본 정보 수정     |
| 프로필   | GET /api/v1/users/me/profile       | 확장 프로필 조회              |
| 프로필   | PATCH /api/v1/users/me/profile     | 자기소개·직업·지역 등 수정        |
| 선호 조건 | GET /api/v1/users/me/preferences   | 매칭 선호 조건 조회            |
| 선호 조건 | PATCH /api/v1/users/me/preferences | 선호 성별·나이·랜덤통화 허용 여부 수정 |

## 7. 보안 및 운영 기준

- provider token 은 클라이언트 값을 그대로 신뢰하지 않고 서버에서 직접 검증한다.
- Refresh Token 은 원문 저장 대신 hash 저장을 기본 원칙으로 한다.
- 탈퇴는 즉시 물리 삭제보다 soft delete 를 우선 적용해 결제·신고·운영 로그와의 정합성을 유지한다.
- 애플 로그인은 이메일 값이 항상 일관되지 않을 수 있으므로 provider\_user\_id 를 중심 식별자로 사용한다.
- 마지막 로그인 수단만 남은 상태에서의 연동 해제, 중복 닉네임 정책, 휴면/정지 상태 처리 기준을 초기에 확정한다.

## 8. 정리

- 본 문서는 REALMATCH+ 전체 제안서 중 로그인·회원·사용자 정보 영역만 독립적으로 정리한 설계 기준 문서다.
- 핵심은 소셜 로그인 수단이 여러 개여도 내부 사용자 계정은 하나로 유지하고, 인증 도메인과 프로필 도메인을 분리하는 것이다.
- 이 구조를 먼저 확정하면 이후 매칭, 랜덤통화, 결제, 커뮤니티 기능을 안정적으로 확장할 수 있다.